

Payatu Case Study

ISO 27001 Transformation for a \$150M Tech Enterprise



Project Overview

A \$150M technology group known for its diverse product portfolio ranging from advanced battery systems (powering EVs, mobile devices, and even submarines) to mission-critical traffic control solutions, had scaled rapidly across sectors with varying regulatory and operational demands.

As the business expanded, so did the complexity of its data landscape: sensitive design files, embedded firmware, supply chain integrations, and remote service interfaces, all operating under different risk profiles.

What the leadership recognized was clear: **growth without governance posed long-term risks.**

To address this, the company decided to implement ISO/IEC 27001 across two of its subsidiaries, viewing it not just as a compliance exercise, but as a foundation for enterprise-wide security governance.

The goal was to enforce consistent access control, data handling, and risk management practices across engineering, manufacturing, and infrastructure teams.

Payatu was brought in to lead the implementation and enforce pragmatic approach to building a GRC framework that aligned with the company's operational realities while meeting international standards.

Let's take a look at how things panned out for this tech leader!

The Scope



End-to-end implementation of ISO/IEC 27001 across two distinct business units:

1. Battery Manufacturing Subsidiary
2. Traffic Control Systems Subsidiary



Asset and risk identification across both IT and OT environments



Policy and control framework development tailored to each business function



Implementation of governance processes including but not limited to access control, incident management, and vendor risk



Internal audit readiness and support for ISO/IEC 27001 certification

Process

The client was guided through a structured, multi-phase approach to implement ISO/IEC 27001 from the ground up.



1. Scoping and Gap Assessment

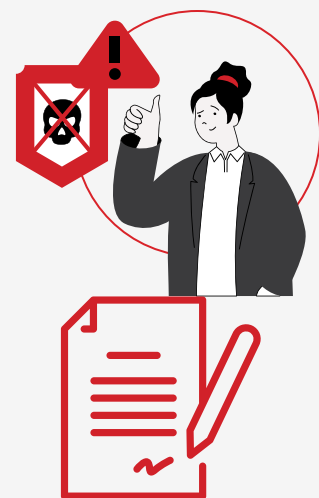
The engagement began with identifying the scope of the ISMS implementation, including relevant departments, business processes, and critical assets.

A detailed gap assessment was conducted to evaluate the current posture against ISO 27001 requirements. The analysis revealed that most foundational controls were either missing or inconsistently applied.

2. Risk Assessment and Risk Register Development

Following the gap analysis, a risk assessment was carried out by mapping each asset and process against the CIA triad (Confidentiality, Integrity, Availability).

A comprehensive risk register was created, detailing asset types, associated processes, risk impact, and likelihood.





3. Control Implementation and Documentation

With risks prioritized and treatment strategies defined, the Bandits supported the client in designing and deploying all necessary security controls.

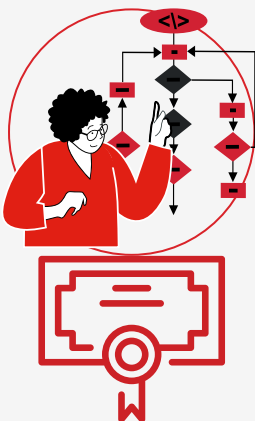
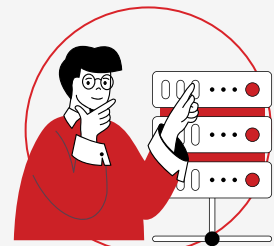
This included drafting and operationalizing core ISMS policies, procedures, and governance workflows – most of which were built from scratch due to the absence of an existing GRC framework.

4. Internal Audit and Remediation

The team conducted an internal audit to validate readiness for certification.

Non-conformities were identified and documented in a formal audit report.

The client addressed each finding systematically, with the team providing guidance on remediation where needed.



5. External Audit and Certification

Once all non-conformities were resolved, the client proceeded with the external audit.

The ISMS passed certification successfully, marking a significant milestone in establishing a structured, compliant, and scalable security governance framework.

Challenges



Limited Awareness of ISMS Requirements

Lack of complete awareness around ownership, documentation, and control implementation led to requiring additional effort in training and alignment.



Delays in Control Implementation

Operational dependencies or process redesigns led to slower execution.

Findings

STANDARD REFERENCE	CLAUSE REFERENCE	TYPE OF FINDING	STATEMENT	DEPARTMENT
ISMS	A 6.1 Screening 8.3 Information access restriction	Minor Non-Conformity	Access Prior to Background Verification Access restrictions were not enforced prior to completion of background verification (BGV), increasing the risk of unauthorized access by unverified personnel.	HR
ISMS	A 6.3 Information Security Awareness, Education, and Training	Minor Non-Conformity	Inadequate Coverage of Security Awareness Training Only 7 out of 54 employees completed the information security awareness training, indicating insufficient reach and coverage of the training program.	HR, MR, and IT
ISMS	6.6 Confidentiality or non-disclosure agreements 5.19 Information security in supplier relationships 5.20 Addressing information security within supplier agreements	Minor Non-Conformity	Missing NDA from BGV Vendor While BGV services were outsourced, a signed NDA with the service provider was not available, posing a legal and confidentiality risk.	HR
ISMS	5.2 Information security roles and responsibilities 5.3 Segregation of duties	Minor Non-Conformity	Undefined Information Security Roles in HR Roles and responsibilities related to information security for HR Executives and Managers were not defined or documented, leading to potential gaps in accountability.	HR
ISMS	5.2 Information security roles and responsibilities 5.3 Segregation of duties	Minor Non-Conformity	Undefined Information Security Roles in HR Roles and responsibilities related to information security for HR Executives and Managers were not defined or documented, leading to potential gaps in accountability.	HR and IT

STANDARD REFERENCE	CLAUSE REFERENCE	TYPE OF FINDING	STATEMENT	DEPARTMENT
ISMS	5.5 Contact with authorities 5.6 Contact with special interest groups	Minor Non-Conformity	Incomplete External Contact Procedure No defined procedure existed for determining when and how authorities or special interest groups should be contacted. The documented list of contacts remained blank.	IT
ISMS	5.9 Inventory of information and other associated assets	Minor Non-Conformity	Inaccurate Asset Inventory Records Inconsistencies in asset registration dates affected the accuracy and reliability of the asset inventory, impacting classification and lifecycle management.	IT
ISMS	5.13 Labelling of information	Minor Non-Conformity	Absence of Information Labelling Practices Information and associated assets were not labelled in accordance with the classification scheme, weakening controls around data handling and confidentiality.	IT
ISMS	5.15 Access control 5.18 Access rights	Minor Non-Conformity	Access Control Matrix Not Maintained The Access Control Matrix document was blank, resulting in unclear access rights and potential mismanagement of user privileges.	IT
ISMS	5.22 Monitoring, review and change management of supplier services	Minor Non-Conformity	Undocumented Subsidiary Separation Plan The change management process related to the segregation of Subsidiary 1 and Subsidiary 2 was not documented, creating risk in supplier service continuity and compliance.	HR, MR and IT
ISMS	5.30 ICT readiness for business continuity	Minor Non-Conformity	Incomplete Business Impact Analysis (BIA) Critical sections of the BIA, including Table 1.5, were blank - hindering the organization's ability to define recovery objectives and plan for ICT continuity.	IT

STANDARD REFERENCE	CLAUSE REFERENCE	TYPE OF FINDING	STATEMENT	DEPARTMENT
ISMS	7.1 Physical security perimeters	Minor Non-Conformity	7.1 Physical security perimeters The Physical and Environmental Security policy states all fire doors were access-controlled; however, fire exits are not, leading to inconsistencies that may affect emergency egress compliance.	Safety & IT
ISMS	7.2 Physical entry	Minor Non-Conformity	ID Data Handling Non-Compliance Visitor ID data was collected during entry, but there was no evidence of safeguards aligned with the government regulatory requirements, exposing the organization to legal risks.	Safety & Admin / MR
ISMS	7.4 Physical security monitoring	Opportunity for Improvement	Insufficient CCTV Log Retention CCTV footage was retained for 90 days, falling short of the 180-day minimum mandated under the IT Act 2000.	PNS & Admin
ISMS	8.14 Redundancy of information processing facilities	Opportunity for Improvement	Lack of Redundancy in Processing Facilities Only one processing facility was in place, with no alternate site or redundant system components, affecting availability during disruptions.	IT & MR
ISMS	8.8 Management of technical vulnerabilities	Minor Non-Conformity	No Test Environment for Patching Patches were applied directly to production systems without prior testing, posing a significant risk to availability and stability.	IT
ISMS	8.28 Secure coding	Minor Non-Conformity	Secure Coding Practices Not Implemented The absence of secure coding standards during development increased exposure to vulnerabilities and compromises application security posture.	Software Innovation

Before Vs After

AREA	BEFORE 	AFTER 
Governance	No defined roles or structure.	Roles, responsibilities, and governance formalized.
Access Control	Ad-hoc access, no matrix, no BGV enforcement.	Role-based access tied to BGV; matrix in place.
Risk Management	No structured risk identification or treatment.	Risk register, assessment, and treatment plan established.
Policies	Missing or generic; not enforced.	Complete ISMS policy framework in place.
Awareness	13% trained; no ongoing program.	Company-wide awareness training with tracking.
Vendor Security	No NDA or defined third-party controls.	NDAs signed; third-party access controlled.
Asset Management	Incomplete inventory; no labelling.	Inventory aligned; data classified and labelled.
Audits & Incidents	No audit process; reactive incident handling.	Internal audits, response plans, and tracking in place.
App & Patch Security	No secure coding; patches applied directly.	Secure coding practices; test environment used.
Physical Security	Policy gaps; ID data not protected.	Policies aligned with safety and legal norms.

Business Impact

100% Closure of Audit Non-Conformities

All audit findings were resolved before external certification, ensuring zero delays in certification readiness.

80% Reduction in Access Provisioning Gaps

Access requests now follow a standardized matrix with BGV enforcement, eliminating uncontrolled access paths.

100% Vendor Compliance

All active third-party vendors now operate under valid NDAs and defined security obligations.

Zero Major Non-Conformities in External Audit

Certification achieved in the first attempt without delays or escalations.

2X Improvement in Risk Visibility

From no formal risk tracking to a live, organization-wide risk register with ownership, impact ratings, and treatment timelines.

30% Decrease in Operational Response Time to Security Issues

With defined controls and roles, incident response and remediation timelines improved significantly.

About Payatu

Payatu is a Research-powered cybersecurity services and training company specialized in IoT, Embedded Web, Mobile, Cloud, & Infrastructure security assessments with a proven track record of securing software, hardware and infrastructure for customers across 20+ countries.



Governance, Risk, and Compliance (GRC) [↗](#)

As organisations grow, so does the complexity of managing risk and meeting regulatory demands. Payatu's GRC services help build a resilient foundation by aligning security practices with global standards like ISO 27001, 42001, 22301, 27701, and GDPR. Whether it's implementing an ISMS, conducting risk assessments, or supporting audit readiness, Payatu empowers businesses to enforce structured governance, reduce risk exposure, and drive sustainable compliance across operations.



Web Security Testing [↗](#)

Internet attackers are everywhere. Sometimes they are evident. Many times, they are undetectable. Their motive is to attack web applications every day, stealing personal information and user data. With Payatu, you can spot complex vulnerabilities that are easy to miss and guard your website and user's data against cyberattacks.



DevSecOps Consulting [↗](#)

DevSecOps is DevOps done the right way. With security compromises and data breaches happening left, right & center, making security an integral part of the development workflow is more important than ever. With Payatu, you get an insight to security measures that can be taken in integration with the CI/CD pipeline to increase the visibility of security threats.



Product Security [↗](#)

Save time while still delivering a secure end-product with Payatu. Make sure that each component maintains a uniform level of security so that all the components “fit” together in your mega-product.



Cloud Security Assessment [↗](#)

As long as cloud servers live on, the need to protect them will not diminish. Both cloud providers and users have a shared. As long as cloud servers live on, the need to protect them will not diminish.

Both cloud providers and users have a shared responsibility to secure the information stored in their cloud Payatu’s expertise in cloud protection helps you with the same. Its layered security review enables you to mitigate this by building scalable and secure applications & identifying potential vulnerabilities in your cloud environment.



Code Review [↗](#)

Payatu’s Secure Code Review includes inspecting, scanning and evaluating source code for defects and weaknesses. It includes the best secure coding practices that apply security consideration and defend the software from attacks.



Red Team Assessment [↗](#)

Red Team Assessment is a goal-directed, multidimensional & malicious threat emulation. Payatu uses offensive tactics, techniques, and procedures to access an organization’s crown jewels and test its readiness to detect and withstand a targeted attack.



IoT Security Testing

IoT product security assessment is a complete security audit of embedded systems, network services, applications and firmware. Payatu uses its expertise in this domain to detect complex vulnerabilities & security loopholes to guard your IoT products against cyberattacks.



Mobile Security Testing

Detect complex vulnerabilities & security loopholes. Guard your mobile application and user's data against cyberattacks, by having Payatu test the security of your mobile application.



Critical Infrastructure Assessment

There are various security threats focusing on Critical Infrastructures like Oil and Gas, Chemical Plants, Pharmaceuticals, Electrical Grids, Manufacturing Plants, Transportation systems etc. and can significantly impact your production operations. With Payatu's OT security expertise you can get a thorough ICS Maturity, Risk and Compliance Assessment done to protect your critical infrastructure.



CTI

The area of expertise in the wide arena of cybersecurity that is focused on collecting and analyzing the existing and potential threats is known as Cyber Threat Intelligence or CTI. Clients can benefit from Payatu's CTI by getting – social media monitoring, repository monitoring, darkweb monitoring, mobile app monitoring, domain monitoring, and document sharing platform monitoring done for their brand.

More Services Offered

- AI/ML Security Audit 
- Trainings 

More Products Offered

- EXPLIoT 
- CloudFuzz 



Payatu Security Consulting Pvt. Ltd.

 www.payatu.com

 info@payatu.io

 +91-20-47248026

 +91-8319812123 (SALES)

